

Project Overview

This project presents a controls and compliance assessment of Botium Toys, a fictional company used as a case study in the Google Cybersecurity Professional Certificate. The objective was to identify security gaps, evaluate compliance best practices, and recommend measures to improve the organization's security posture.

Controls and compliance checklist

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☒	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)
-

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

Recommendations:

It is recommended that Botium Toys implement encryption to protect sensitive data and apply the principle of least privilege, restricting employees' access to only the information necessary to perform their job duties. Separation of duties controls should also be implemented, along with disaster recovery plans and regular backups of critical data.

Password policies should be strengthened by establishing minimum complexity requirements, such as at least eight characters, including uppercase and lower case letters, numbers, and special characters. In addition, a centralized password management system should be adopted.

It is also important to implement an intrusion detection system (IDS) and establish a regular schedule for monitoring, maintenance, and intervention for legacy systems.

Botium Toys should also establish and maintain an asset inventory and classification process to properly identify and manage critical assets based on their sensitivity and business impact.

These measures would help reduce the identified risks, improve compliance with security best practices, and strengthen the confidentiality, integrity, and availability of Botium Toys' information.